

Universidad Nacional Autónoma de México



Facultad de Ingeniería

Alumno:

Lara Hernandez Angel Husiel - 320060829

Lugo Manzano Rodrigo - 320206968

Flores Colin Victor Jaziel - 320266083

Garcia Cortes Adolfo de Jesus - 320317264

Seguridad informatica basica

Semestre: 2027-1

Actividad 7

Análisis de Riesgos: Caso General del Grupo Groq (`RK-007` / `RK-007a`) — VELOX Automotriz S.A. de C.V.

Fecha de Entrega:

7 de Noviembre del 2026

Índice

1 Contexto del Escenario de Riesgo: Caso Grupo Groq (`RK-007 / RK-007a`) 1

2 Plantilla Completa de Análisis de Riesgos (Hoja 1: Formato) 1

2.1 Secciones I, II y III: Resumen, Descripción y Evaluación Cuantitativa 1

2.2 Secciones IV y V: Respuesta al Riesgo, Plan de Acción y Monitoreo 4

3 Síntesis Matemática del Cálculo de Riesgo 5

Referencias 6

1. Contexto del Escenario de Riesgo: Caso Grupo Groq (RK-007 / RK-007a)

Retomando el registro de riesgos de **VELOX Automotriz S.A. de C.V.** desarrollado en la actividad previa (National Institute of Standards and Technology, 2012; SAE International, 2021), el presente documento traslada y desarrolla a detalle la plantilla completa de **Análisis de Riesgos** para el escenario del **Grupo Groq** (RK-007 / RK-007a: *ShadowAI — Depuración de código y firmware en GroqCloud y servicios de IA no autorizados*) (Myles, 2026; OWASP Foundation, 2025).

#	ID	Nombre del Riesgo	Escenario — Forma 1 (Orientado al Impacto y Proceso Operativo)	Escenario — Forma 2 (Orientado al Actor / Adversario y Activo Comprometido)
7	RK-007	ShadowAI (Uso no autorizado de Groq, Claude, DeepSeek y navegadores con IA)	Un empleado utiliza en sus operaciones del día a día la IA de Groq, Claude, DeepSeek o navegadores con servicios de IA integrados sin autorización corporativa, provocando la filtración de código fuente automotriz, secretos de red y datos personales de clientes en servidores externos.	Un actor interno (*Ditto*) o adversario externo que intercepta sesiones de terceros compromete la confidencialidad de las estaciones de ingeniería, Confluence, ServiceNow y el código del portal corporativo al procesar datos confidenciales en plataformas externas de IA (CWE-200, OWASP LLM06).
7.1	RK-007a	ShadowAI — Groq (Depuración de código y firmware en GroqCloud)	Un ingeniero pega bloques de código propietario de la ECU Principal (VCU) y microservicios Node.js en la plataforma de inferencia rápida Groq para resolver fallos del día a día, exponiendo algoritmos de control vehicular y llaves API de AWS/Vault.	Un colaborador con privilegios de desarrollo compromete la confidencialidad del repositorio de firmware Renesas RH850, los microservicios del portal corporativo y los secretos de HashiCorp Vault al enviarlos a los servidores externos de Groq.

2. Plantilla Completa de Análisis de Riesgos (Hoja 1: Formato)

A continuación se presenta la tabla íntegra del análisis de riesgos elaborada en la primera hoja (Formato) del libro de Excel, siguiendo la estructura de cinco secciones (**Sección I — Resumen**, **Sección II — Descripción del riesgo**, **Sección III — Análisis de Riesgo**, **Sección IV — Respuesta al riesgo** y **Sección V — Monitoreo**) y el código de colores del ejemplo de referencia (donde las casillas en **gris** indican el valor o categoría seleccionada).

2.1. Secciones I, II y III: Resumen, Descripción y Evaluación Cuantitativa

Sección I - Resumen			
ID del riesgo	RK-007 (RK-007a)	**Nivel de Riesgo**	**ALTO**
Nombre del riesgo	ShadowAI — Groq (Depuración de código y firmware en GroqCloud)	**Respuesta al riesgo**	**MITIGAR / EVITAR**
Propietario del riesgo	CISO, Oficial de Privacidad (DPO) y Director de Ingeniería de Software	**Estado del plan de acción**	**EN IMPLEMENTACIÓN (70 %)**
Descripción del riesgo	Filtración de código fuente automotriz (VCU/Node.js), algoritmos y llaves API en GroqCloud por uso no autorizado de IA	**Última evaluación del riesgo**	**29/08/2026**

Sección II - Descripción del riesgo						
Nombre del riesgo	ShadowAI — Groq (Uso no autorizado de GroqCloud, Claude, DeepSeek y navegadores con IA en operaciones diarias)					
Categoría de riesgo	Estratégico	Programa	Proyecto	**Operativo**	Otro:	
Escenario de alto nivel	Un ingeniero de desarrollo pega bloques de código propietario de la ECU Principal (VCU Renesas RH850) y microservicios Node.js en la plataforma externa de inferencia rápida GroqCloud para depurar fallos del día a día sin autorización corporativa. Esto compromete la confidencialidad del repositorio de firmware, algoritmos críticos de control vehicular y secretos de HashiCorp Vault / llaves API de AWS al procesarlos en servidores externos sin acuerdo TISAX, provocando pérdida de ventaja competitiva e incumplimiento con socios Tier 1.					
Descripción detallada del riesgo	**Evento**	Exposición y filtración de código fuente propietario (VCU/Node.js) y llaves API en servidores externos de GroqCloud por uso de ShadowAI				
	Activo / Recurso	Estaciones de ingeniería, repositorio de firmware Renesas RH850 (VCU), microservicios Node.js (`connect.veloxauto.mx`) y secretos de HashiCorp Vault / AWS				
	Tipo de Amenaza	Amenaza Interna (Insider / Colaborador) e Interceptación en Plataformas Externas de IA (`CWE-200`, `OWASP LLM06`)				
	Actor	*Ditto* (Colaborador con privilegios de desarrollo / Actor interno) o adversario externo que intercepta sesiones de terceros				
	Probabilidad	Alta				
	Consecuencias	Exfiltración de algoritmos de control vehicular y propiedad intelectual ADAS/VCU, exposición de llaves API de AWS/Vault e incumplimiento con socios Tier 1				
Otra información del escenario	Clasificado bajo `CWE-200` y `OWASP LLM06` (*Sensitive Information Disclosure*). El caso general del grupo Groq (`RK-007`) abarca también la filtración de tickets ITSM/ERP en Claude (`RK-007b`) y lectura del DOM/SIEM en DeepSeek y navegadores IA (`RK-007c`).					
Sección III - Análisis de Riesgo						
Frecuencia						
Ocurrencia Anual	0.0	1.0	2.0	3.0	**4.0**	5.0
	$N \leq 0.01$	$0.01 < N \leq 0.1$	$0.1 < N \leq 1$	$1 < N \leq 10$	$\mathbf{10 < N \leq 100}$	$100 < N$
Comentarios sobre la frecuencia	Considerando las 85 estaciones de trabajo de ingeniería y las 420 laptops corporativas de VELOX, el uso cotidiano de GroqCloud para depurar fallos de código VCU y microservicios Node.js genera entre 10 y 100 eventos de exposición de código o secretos al año ($10 < N \leq 100$).					
Impacto						
Pérdida de ganancia anual	0.0	1.0	2.0	3.0	**4.0**	5.0
	$I \leq 0.1\,\%$	$0.1\,\% < I \leq 1\,\%$	$1\,\% < I \leq 3\,\%$	$3\,\% < I \leq 5\,\%$	$\mathbf{5\,\% < I \leq 10\,\%}$	$10\,\% < I$
Comentarios sobre la pérdida	La filtración de algoritmos propietarios de la VCU (Renesas RH850) y llaves API de AWS/Vault causaría pérdida de ventaja competitiva en vehículos eléctricos, costos de respuesta a incidentes en la nube y suspensión de contratos con socios Tier 1, representando entre el 5 % y el 10 % de la ganancia anual.					
Costo de la respuesta al riesgo	0.0	**1.0**	2.0	3.0	4.0	5.0
	$I \leq \$10\text{k}$	$\mathbf{\$10\text{k} < I \leq \$100\text{k}}$	$\$100\text{k} < I \leq \$1\text{M}$	$\$1\text{M} < I \leq \$10\text{M}$	$\$10\text{M} < I \leq \$100\text{M}$	$\$100\text{M} < I$
Comentarios sobre el costo de la respuesta	La respuesta aprovecha controles ya existentes en VELOX (políticas GPO en Active Directory y módulo CASB en FortiGate 600F), requiriendo únicamente licenciamiento de Endpoint DLP para estaciones de ingeniería y el despliegue de IA privada empresarial en AWS Bedrock, con un costo anual estimado de \$45,000 USD ($\$10,000 < I \leq \$100,000$).					
Impacto reputacional	0.0	1.0	2.0	**3.0**	4.0	5.0
	$I \leq 0.5$	$0.5 < I \leq 1$	$1 < I \leq 1.5$	$\mathbf{1.5 < I \leq 2}$	$2 < I \leq 2.5$	$2.5 < I$
Comentarios sobre el impacto reputacional	En caso de materializarse la exposición de código de control vehicular (VCU), diseños ADAS o datos personales/VIN de clientes en plataformas de IA externas, VELOX Automotriz perdería entre 1.5 y 2.0 puntos de reputación ante clientes y fabricantes OEM/Tier 1.					

Costo de multas por incumplimiento	0.0	1.0	**2.0**	3.0	4.0	5.0
	$0.00	< $1M	< **$10**M	< $100M	< $1B	> $1B
Comentarios sobre el incumplimiento regulatorio	La transferencia de propiedad intelectual compartida y datos personales (PII/VIN) hacia servidores de IA sin acuerdo TISAX incumple convenios de confidencialidad (NDA) con socios Tier 1, normativas ISO/SAE 21434 y leyes de protección de datos, implicando multas y penalizaciones de hasta $10M USD (< $10M).					
Calificación general del impacto (promedio de los 4 aspectos)						**2.50**
Calificación general del nivel de riesgo (Frecuencia × Impacto)						**10.00**

2.2. Secciones IV y V: Respuesta al Riesgo, Plan de Acción y Monitoreo

Sección IV - Respuesta al riesgo				
Respuesta seleccionada:	Aceptar	Transferir	**Mitigar**	**Evitar**
Justificación	El riesgo presenta un nivel ALTO (calificación de 10.0) y no puede ser aceptado debido al impacto crítico que tendría la filtración del firmware de la VCU (Renesas RH850), los microservicios Node.js y los secretos de HashiCorp Vault/AWS en la seguridad operacional y competitividad de VELOX Automotriz. Dado que el costo de implementación es bajo en comparación con las pérdidas potenciales, se decide **MITIGAR** el riesgo mediante reglas DLP en endpoints, control CASB en FortiGate y el despliegue de IA privada en AWS Bedrock, así como **EVITAR** la exposición bloqueando navegadores/extensiones de IA no autorizados y dominios sin acuerdo TISAX.			
Estatus general del plan de acción	En implementación (70 % completado: reglas DLP y política GPO activas)			
Problemas relevantes de las acciones de respuesta	Falsos positivos iniciales en reglas DLP al analizar fragmentos legítimos de código C/Node.js y resistencia al cambio por parte de desarrolladores acostumbrados a la baja latencia de GroqCloud.			
Hitos conseguidos en las acciones de respuesta	Reglas DLP activas en las 85 estaciones de ingeniería; política GPO desplegada en Active Directory bloqueando extensiones/navegadores IA no autorizados; bloqueo CASB activo en FortiGate 600F (70 % de avance).			

Plan de acción			
#	**Acción de respuesta**	**Fecha compromiso**	**Estatus**
1.0	Aplicar política GPO en Active Directory para bloquear navegadores con IA integrada y extensiones no autorizadas en estaciones de ingeniería y laptops	10/08/2026	Completado
2.0	Configurar e implementar reglas de Endpoint DLP para prevenir el pegado y envío de código fuente (VCU/Node.js), datos PII/VIN y llaves API de AWS/Vault	18/08/2026	Completado
3.0	Activar control CASB e inspección SSL en el firewall FortiGate 600F para bloquear dominios de IA externos (GroqCloud, DeepSeek, Claude personal) sin acuerdo TISAX	25/08/2026	Completado
4.0	Desplegar plataforma de asistencia de IA privada corporativa en AWS Bedrock con garantía de cero retención de datos para uso de los ingenieros de software y firmware	15/09/2026	En progreso
5.0	Rotar secretos expuestos en HashiCorp Vault / AWS IAM y capacitar al personal técnico en la política corporativa de uso seguro de IA generativa	30/09/2026	En progreso

Sección V - Monitoreo			
Última evaluación del riesgo	29/08/2026	**Siguiente evaluación**	29/09/2026

Indicadores clave de riesgo (KRIs)			
#	**Indicador**	**Medición**	**Fecha**
1.0	Intentos mensuales de envío de código fuente o llaves API a GroqCloud y dominios de IA bloqueados por DLP / FortiGate CASB	14 alertas/mes	29/08/2026
2.0	Porcentaje de estaciones de trabajo de ingeniería y laptops con política GPO anti-ShadowAI y agente DLP activos	100 % (505/505)	29/08/2026

3.0	Porcentaje de desarrolladores de firmware VCU y backend migrados al entorno privado autorizado en AWS Bedrock	70 % completado	29/08/2026

3. Síntesis Matemática del Cálculo de Riesgo

De acuerdo con la metodología cuantitativa empleada en la plantilla de análisis de riesgos (National Institute of Standards and Technology, 2012):

1. **Frecuencia Anual (F):** Se asigna un valor de $F = 4.0$, correspondiente al rango $10 < N \leq 100$ eventos anuales de uso no autorizado de GroqCloud para depuración de código y firmware en las estaciones de ingeniería.

2. **Calificación General del Impacto (I_{prom}):** Se obtiene como la media aritmética de los cuatro rubros de impacto evaluados en escala de 0.0 a 5.0:

$$I_{\text{prom}} = \frac{I_{\text{ganancia}} + I_{\text{costo_respuesta}} + I_{\text{reputacional}} + I_{\text{multas}}}{4} = \frac{4.0 + 1.0 + 3.0 + 2.0}{4} = \frac{10.0}{4} = 2.50$$

3. **Calificación General del Nivel de Riesgo (R):** Se calcula como el producto de la frecuencia por la calificación general del impacto:

$$R = F \times I_{\text{prom}} = 4.0 \times 2.50 = 10.00 \quad \Longrightarrow \quad \textbf{Nivel de Riesgo: ALTO}$$

Referencias

Myles, P. (2026). *AI doubled auto industry cyberattacks: Upstream 2026 Global Automotive and Smart Mobility Cybersecurity Report*. WardsAuto. Consultado el 31 de octubre de 2026, desde https://www.wardsauto.com/news/ai-doubles-automotive-cyber-attacks-sdvs-updtream/813455/

National Institute of Standards and Technology. (2012). *Guide for Conducting Risk Assessments (NIST SP 800-30 Rev. 1)* (inf. téc.). NIST. https://nvlpubs.nist.gov/nistpubs/Legacy/SP/nistspecialpublication800-30r1.pdf

OWASP Foundation. (2025). *OWASP Top 10 for Large Language Model Applications (LLM06: Sensitive Information Disclosure)*. OWASP. Consultado el 31 de octubre de 2026, desde https://genai.owasp.org/llm-top-10/

SAE International. (2021). *ISO/SAE 21434: Road Vehicles – Cybersecurity Engineering*. SAE International. Consultado el 31 de octubre de 2026, desde https://www.sae.org/standards/content/iso_sae21434/